Week 2 — Assessing Security Culture

Overview

This week shifted focus from external threats to the **human element** of security — arguably the most exploited attack surface in any organization. The assignment involved designing a security awareness program to address a real-world scenario involving insider risk and poor security culture.

Topics Covered

- Security culture and its role in organizational risk
- The psychology behind social engineering attacks
- Security awareness training program design
- Policy development and enforcement strategies
- Measuring and improving security posture

Assignment

Developed a comprehensive **Security Awareness Plan** for a fictional organization that had experienced an insider-driven security incident. The plan included:

- Root cause analysis of the cultural failure
- A phased employee training rollout
- Policy recommendations (acceptable use, data handling, reporting procedures)
- Metrics to track improvement over time
- Executive-level summary and justification

Key Concepts

Security Culture Pillars

- Leadership buy-in and tone from the top
- Continuous training vs. one-time compliance exercises
- Clear incident reporting channels (reducing fear of reporting)
- Regular phishing simulations and drills

Common Human-Factor Vulnerabilities

- Phishing and spear-phishing susceptibility

- Tailgating and physical security lapses
- Password reuse and poor credential hygiene
- Oversharing on social media (enabling OSINT attacks)

Frameworks Referenced

- NIST SP 800-50 (Building an IT Security Awareness and Training Program)
- CIS Controls — Awareness and Skills Training (Control 14)